SoK: A Systematic Literature Review of Knowledge-Based Authentication on Augmented Reality Head-Mounted Displays

Reyhan Duezguen
Karlsruhe Institute of Technology
Karlsruhe, Germany
reyhan.duezguen@kit.edu

Naheem Noah
University of Denver
Denver, Unites States
naheem.noah@du.edu

Peter Mayer
Karlsruhe Institute of Technology
Karlsruhe, Germany
peter.mayer@kit.edu

Sanchari Das
University of Denver
Denver, Unites States
sanchari.das@du.edu

Melanie Volkamer
Karlsruhe Institute of Technology
Karlsruhe, Germany
melanie.volkamer@kit.edu

ABSTRACT

The adoption of Augmented Reality (AR) technology has increased over the years. AR enhances various activities for consumers and businesses, particularly in industrial contexts. The three-dimensional virtual experience is realized by the usage of Head-Mounted Displays (HMD). These devices provide access to sensitive data and services. Thus, secure and usable authentication schemes are essential to control access to the HMD and the stored data as well as schemes to authenticate to the services one wants to use with the AR device. We conducted a systematic literature review on knowledge-based authentication schemes for AR HMD. 31 different schemes were identified. These schemes were assessed regarding various aspects including the type of AR HMD, the type of secret, how users input their secret, as well as usability and security aspects. We discuss gaps for future work.

CCS CONCEPTS

• **Security and privacy → Usability in security and privacy**.

KEYWORDS

Literature Review, Authentication, Password Entry, Augmented Reality, Head-Mounted Display

ACM Reference Format:
Reyhan Duezguen, Naheem Noah, Peter Mayer, Sanchari Das, and Melanie Volkamer. 2022. SoK: A Systematic Literature Review of Knowledge-Based Authentication on Augmented Reality Head-Mounted Displays. In *The 17th International Conference on Availability, Reliability and Security (ARES 2022), August 23–26, 2022, Vienna, Austria.* ACM, New York, NY, USA, 12 pages. https://doi.org/10.1145/3538969.3539011

1 INTRODUCTION

Authentication is an important layer of computer security provisioning access control to protect sensitive data and infrastructure. Secure authentication ensures the verification of the identity of authorized users attempting to gain access into a system while preventing access to unauthorized users [10]. Particularly, for Augmented Reality (AR) devices, the importance of security cannot be overemphasized as a lot of user information is collected to give users an immersive experience [30]. Lately, AR is witnessing a high level of adoption in fields like education, architecture, healthcare, manufacturing, industrial design etc. [24]. As the level of usage increases, so does the level of perceived threats that are being examined on AR hardware and systems.

AR provides three-dimensional interfaces in which one or more users can interact alone or together as a group in a shared space [36]. These users interact with immersive digital interfaces layered on top of the real-world through the use of head-mounted displays (HMD) [14]. With the use of AR HMD, users are confronted with enormous data access while sharing three-dimensional screen captures and traversing three-dimensional objects in real-time. The increase in the amount of data shared on these systems warrants the need for an extensive security approach. Furthermore, activities such as virtual meetings, remote control, and virtual shopping put users and businesses at more risks of adversary attacks. For users to authenticate in an AR environment, they are forced to either utilize an external device such as smartphones or personal computers to complete the authentication process [9] or use schemes which are not secure and/or user-friendly due to the restricted input modalities of the HMD [28, 29, 33, 44]. The adoption of well-known schemes on smartphones or personal computers causes usability and security issues as they are not tailored to the available interaction mechanisms of the HMD.

Several authentication techniques have been implemented in AR over the years. Proposed authentication schemes use either user's knowledge (e.g., PIN, textual passwords), biometrics (e.g., eye gaze, gait behaviour), what the user possesses (e.g., token or one-time password), or a combination of those.

This paper provides a systematic literature review on knowledge-based authentication schemes for AR HMD. We focused on knowledge-based authentication as this is the most widely used authentication technique chosen by service and device providers. Biometric and possession-based schemes have still many shortcomings and thus require the availability of a knowledge-based scheme as a fallback. Furthermore, biometrics may compromise users' privacy and security in many ways [3] and require sensors or features which

Permission to make digital or hard copies of part or all of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for third-party components of this work must be honored. For all other uses, contact the owner/author(s).
ARES 2022, August 23–26, 2022, Vienna, Austria
© 2022 Copyright held by the owner/author(s).
ACM ISBN 978-1-4503-9670-7/22/08.
https://doi.org/10.1145/3538969.3539011

might not be available in the HMD. Finally, they are also not applicable for all user groups, e.g., elderly or handicapped people [38]. Thus, the availability of usable and secure knowledge-based authentication schemes is essential.

The work by Stephenson et al. [40] is the one most closely related to our work. This paper reviews literature on AR authentication as well as available schemes on two exemplary HMD. But, the authors consider only five publications on knowledge-based authentication schemes. We aim to conduct a systematic literature search to cover all available publications for our review.

With the goal of assessing the current literature on knowledge-based authentication schemes for AR HMD, our research compares these existing schemes to identify the strengths, weaknesses as well as gaps for future research. The literature search resulted into a selection of 18 papers which include 31 authentication schemes in total. These schemes were reviewed regarding the type of secret that is being used for authentication, requirements related to the equipment of the HMD, and usability as well as security aspects. Usability aspects include efficiency, effectiveness and perceived usability. For the security analysis, we reviewed the password space of the schemes as this place an important role when it comes to guessing attacks. We also looked at scheme's resistance against shoulder-surfing attacks as these devices are increasingly used in shared spaces [17].

2 BACKGROUND

This section first describes the characteristics of Augmented Reality and defines the differences to Virtual and Mixed Reality. Then, the basics steps of an authentication process and the various forms of authentication on the HMD are explained.

2.1 Augmented Reality

Augmented Reality (AR) is defined as a technology that superimposes 3-D virtual objects on the real world. The main characteristics of AR include (1) the combination of the real and virtual world, (2) real-time interaction between the physical and virtual environment, and (3) presentation of the virtual objects in 3-D [2]. AR was first introduced by Sutherland [41] in the 60s and enhanced over time to a useful and usable technology available in various forms from AR on smartphones to Head-Mounted-Displays (HMD). This work focuses solely on AR provided on HMD. The term Extended Reality (XR) covers AR as well as Virtual Reality (VR) and Mixed Reality (MR). Virtual Reality (VR) is in contrast to AR immersing the user into a complete 3-D virtual world without allowing the user to see the real world. Thus, VR HMD are equipped differently than AR HMD. As a literature review of authentication on VR HMD already exists [23], we decided to only focus on authentication with AR HMD. Mixed Reality (MR) covers the characteristics of AR but emphasizes the spatial mapping of the real world in real-time and the interaction of the virtual and physical environment [37]. Thus, MR is often used as synonym for AR. Therefore, we decided to treat them as synonym as well.

AR HMD exist with various types of optical solutions and interactions mechanisms. More lightweight HMD, e.g., Google Glass, Epson Moverio or Vuzix provide a small field of view. More heavyweight and bulky HMD, e.g. Microsoft HoloLens or Magic Leap provide a larger field of view and thus a more immersive experience to the user. The virtual environment which is displayed by the optical system is usually only visible to the user. How users interact with virtual objects varies depending on the HMD. This includes, e.g., touch, speech, gestures, gaze input, or controller. Compared to currently popular devices like PC, smartphones or tablets which consist of a public display and use a keyboard or mouse, AR HMD are equipped with different input and output mechanisms. Thus, authentication schemes which are suitable for those popular devices cannot be applied to AR HMD without sacrifices in usability and/or security.

2.2 Authentication on AR HMD

Authentication schemes are required to control access to sensitive data and infrastructure by providing access to only authorized users and denying access to unauthorized users. The user starts with the *enrollment*, where a secret, e.g., a password is chosen by the user or assigned by the system. During *authentication*, the user first enters the user name or user ID which the user claims to be. Then, the user enters the previously defined secret. The system verifies the entered information against the credentials stored during enrollment. If the verification was successful, the system authorizes the user and grants access. Otherwise, access will be denied.

Authentication on an AR HMD can be required to control access (1) on the device itself or (2) to online or offline applications of third parties available on the device. In case of option (2), the user can authenticate directly to the service or via a password manager. Figure 1 illustrates the authentication process and the different use cases.

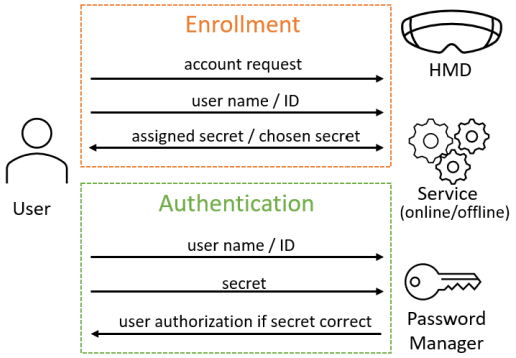

Figure 1: Authentication procedure on the AR HMD.

3 METHODOLOGY

The study aims to identify and review literature on authentication schemes which are proposed for AR HMDs. Our work followed recommendations of [27, 42] for conducting a systematic literature review. The three steps (1) literature search, (2) literature selection, and (3) literature analysis are explained in the following.

3.1 Literature Search

During the decision on appropriate search terms, the following terms were treated as a synonym: "Augmented Reality" and

"Mixed Reality" as well as "smart glasses", "smartglasses", "wearable glasses", "head-mounted display", "head-mounted device", "HMD", "AR device", "AR glasses", "AR display", "AR headset", "wearable device", "smart eye-wear". At least one of these terms had to appear simultaneously with one of the terms "authentication" and "password entry" in the full text of the paper. This resulted in the following search term: *("Augmented Reality" OR "Mixed Reality" OR "smart glasses" OR "smartglasses" OR "wearable glasses" OR "head-mounted display" OR "head-mounted device" OR "HMD" OR "AR device" OR "AR glasses" OR "AR display" OR "AR headset" OR "wearable device" OR "smart eye-wear") AND ("authentication" OR "password entry").*

Following the recommendations of previous work on authentication literature reviews in [5, 35], we searched in the databases ScienceDirect, ACM, IEEE, Springer Link, as well as in additional conferences and journals which are not indexed by the databases above but considered as relevant in authentication research, i.e., Usenix Security Symposium, Symposium On Usable Privacy and Security, Usable Security Workshop, Trustworthy Interfaces for Passwords and Personal Information Workshop, Journal of Computer Security, International Journal of Information Security and Privacy, International Journal of Technology and Human Interaction, Human IT: Journal of information technology studies as a human science, Journal of Information Systems Security and Who Are You? (WAY) workshop. We also add the following journals and conferences which are not indexed by the databases above but publish also AR-related topics: Global Journal of Computer Science and Technology, Presence Teleoperators And Virtual Environments, International Journal Of Interactive Mobile Technologies.

Papers that were not written in English as well as papers from unrelated subject areas, such as material science or medicine, were filtered out. We also removed conferences and journals which are covered multiple times in the above-mentioned databases to reduce overlap. The search term lead to the following number of papers: 1582 in ScienceDirect, 704 in ACM, 106 in IEEE, and 3794 in Springer Link which led to 6186 papers in total. The high amount of search results can be explained by the very broad search term which was necessary due to the broad spectrum of names which were used for AR HMD over time. The publications of the individual venues were searched manually by title as they were missing advanced search functions. The search was not limited to a specific time frame. As the search was conducted in February 2022, only papers published prior to this date were considered.

3.2 Literature Selection

Next, from search results of the databases and individual venues, those papers fulfilling the following three criteria were selected: (1) defining a knowledge-based authentication scheme which is implemented or proposed to be applicable on an AR HMD to control user access on the HMD itself or its applications including third party online services available on user's HMD, (1a) in case of third party services, schemes authenticate the user directly to the service provider (in case the service provider implements an AR HMD authentication scheme directly into their service) or indirectly via a password manager (in case traditional text password must be used), (1b) schemes can deploy additional external hardware to extend the HMD's capabilities, (1c) but do not use an HMD as an additional hardware, i.e., input or output mechanism to control access on another device, e.g., smartphone or ATM, (1d) the selected paper focuses on proposing a scheme for authentication and does not only introduce a technology which might be applicable for authentication; (2) is a peer-reviewed paper or article; (3) is the latest paper on the proposed scheme, e.g., extended journal version.

For selecting relevant papers, the search results were screened by title. Titles that could not be clearly excluded were then scanned by abstract. If necessary, the rest of the paper was scanned as well. The assessment of papers led to a selection of 15 papers from the databases and 3 papers from the individual venues. The forward and backward search of the selected papers did not lead to further relevant papers. In total 18 papers were selected.

3.3 Literature Analysis

The schemes were evaluated regarding technical requirements towards the HMD as well as security and usability aspects. The technical requirements include input and output mechanisms the scheme relies on and the type of HMD for which the scheme is implemented in the paper. Thereby, the maturity of the implementation was also considered. We reviewed the usability and security of the schemes as far as these evaluations were available in the papers. We searched for the following criteria when assessing usability: efficiency, effectiveness, satisfaction, and perceived ease of use. The criteria for assessing the security include password strength against guessing attacks, perceived security, and resistance towards shoulder-surfing. These criteria were determined during the evaluation of the paper collection based on the available investigations reported in the papers.

4 SELECTED SCHEMES

This section describes the knowledge-based authentication schemes we found in our detailed literature search. The literature search resulted in a selection of 18 relevant papers which present 31 different authentication schemes in total. Table 1 shows an overview of the selected papers with each schemes secret type, technical requirements towards the HMD, degree implementation and conducted usability and security studies.

14 schemes (45%) were proposed for the Google Glass, 4 schemes (13%) for the Microsoft HoloLens and 2 schemes (6%) for the Epson Moverio BT-200. 11 (35%) of the schemes did not specify which specific HMD they had in mind. User input is considered from touch pad, speech recognition, gyroscope & accelerometer, eye tracking, gesture tracking, front camera, and Electrooculography (EOG) sensors with a frequency of 10 (32%), 10 (32%), 4 (13%), 4 (13%), 4 (13%), 2 (6%), and 2 (6%) respectively among all schemes. 25 (81%) of the schemes rely on the private display of the HMD.

We categorized the schemes in the following groups according the type of their secret: alphanumeric passwords, graphical passwords, haptic patterns, semantic-knowledge passwords and schemes with two-factor authentication. The frequency of the proposed secret types are 48%, 13%, 13%, 3% and 23% respectively.

In the following, we describe each of the schemes. The descriptions consist of a brief introduction of the scheme, the type of secret the scheme uses, the HMD device it applies to, and the equipment

Table 1: Schemes grouped according the type of secret. GG=Google Glass, MH=Microsoft HoloLens, EM=Epson Moverio, N.s.=not specified, *user study includes perceived security.

				Required Equipment		Study Sample Size		
Password Type	Paper	Scheme Name	HMD	Input	Private Display Output	Usability	Security	Degree of Implementation
Alphanumeric Password	Li et al. (2021)	gTapper	GG	touch pad	PIN pad	57	-	fully implemented
		gRotator	GG	touch pad & gyroscope	PIN pad	57	-	fully implemented
		gTalker	GG	speech recognition	PIN pad	57	-	fully implemented
	Zhang et al. (2017)	AugAuth	n.s.	armband for gesture recognition	PIN pad	6	-	gesture recognition
	Seo et al. (2017)	MaskedPwd (voice)	GG	speech recognition	number series	10	-	only on smartphone
		MaskedPwd (touch)	GG	touch pad	number series	10	-	only on smartphone
	Gheorghe et al. (2016)	Thermal Touch Input	n.s.	thermal front camera	pin pad	-	-	only on smartphone
	Yadav et al. (2015)	VBP	GG	speech recognition	pin pad	30*	-	fully implemented
		TBP	GG	touch pad	pin pad	30*	-	fully implemented
	Bailey et al. (2014)	Indirect input - PIN	GG	speech recognition	number series	-	-	proposal
		Covered PIN	GG	speech recognition	pin pad	-	-	proposal
		Covered Char Pwd	GG	speech recognition	keyboard	-	-	proposal
	Khare et al. (2011)	GesturePIN	n.s.	gesture tracking	-	-	-	gesture recognition
	Li et al. (2015)	ShadowKey PIN	n.s.	speech recognition	pin pad	-	-	proposal
		ShadowKey Char Pwd	n.s.	speech recognition	keyboard	-	-	proposal
Graphical Password	Friström et al. (2019)	Free-from gaze pwd	n.s.	eye tracking	-	19*	6	only with eye tracking glasses
	Funk et al. (2019)	LookUnlock (virtual)	MH	eye tracking	virtual objects	-	15	fully implemented
	Hadjidemetriou et al. (2019)	HoloPass	MH	gesture tracking	picture	15	-	fully implemented
	Bailey et al. (2014)	Covered Graphical Password	GG	speech recognition, touch pad, gyroscope & accelerometer	image grid	-	-	proposal
Haptic Pattern	Islam et al. (2018)	GlassPass (disclosed)	EM	special touch pad	user input	24	-	fully implemented
		GlassPass (non disclosed)	EM	special touch pad	user input	24	-	fully implemented
	Yadav et al. (2015)	Google Built-in	GG	touch pad	-	30*	-	fully implemented
	Hutchins et al. (2018)	Beat-PIN	n.s.	touch pad	-	49	49	only on smart watch
Semantic-Knowledge Password	Duezguen et al. (2020)	ZeTA	GG	touch pad, speech recognition, gyroscope	challenges	-	-	proposal
2FA	Yi et al. (2016)	GlassGesture	GG	accelerometer & gyroscope	challenges	18	5	fully implemented
	Findling et al. (2019)	GazeGesture-Pwd (closed eye)	n.s.	EOG sensors	user input	15	18	gesture recognition
		GazeGesture-Pwd (closed eye)	n.s.	EOG sensors	user input	15	18	gesture recognition
	Lu et al. (2021)	Passcode	n.s.	gesture tracking	user input	90	10	gesture recognition
	Azimpourkivi (2017)	Pixie	n.s.	front camera	-	42*	-	only on smartphone
	Funk et al. (2019)	LookUnlock (spatial)	MH	eye tracking	-	-	15	fully implemented
		LookUnlock (hybrid)	MH	eye tracking	virtual objects	-	15	fully implemented

of the HMD that performs the authentication. Also, the enrollment and authentication procedure are described in detail.

4.1 Based on alphanumeric passwords

This section describes the schemes of our selected papers which are based on the use of alphanumeric passwords, like Personal Identification Numbers (PIN) or textual passwords with larger password spaces. Alphanumeric passwords can include elements like digits, characters, as well as symbols.

Li et al. [31] proposed three authentication schemes for entering a PIN on the AR HMD; gTapper, gRotator, and gTalker. The schemes were implemented for Google Glass and the equipment used for entering the PIN are touch pad, gyroscope, and speech recognition respectively.

Enrollment: The user and server agree on the PIN length. Then, the user chooses a PIN using an external device or the same approach as for authentication; or a PIN is assigned to the user and displayed to the user on the AR HMD.

Authentication: The PIN pad will be shown on the private display of the glass. Entering the PIN can happen in one of the following three ways depending on the version proposed: In 1) gTapper the user enters the PIN by using the touch pad. For each entry, a random number on the PIN pad will be focused as a starting point. The user shifts the focus to a different number by swiping on the touch pad to select the right number and entering the number with a tap.

In 2) gRotator the user enters the PIN via head rotation movements captured by the gyroscope. The PIN pad is divided into 2 screens with 5 numbers on each. Only one of the screens will be shown to the user at a time. The 5 numbers and their position will be randomly shuffled for each entry. To select a number, the user needs to rotate the head according to the head movement assigned to that number. If the number is not available on the current screen, the user needs to change to the other screen by swiping forward

on the touch pad. In 3) gTalker the user enters the PIN via speech. The PIN pad consists of the numbers displayed in white and next to them are underlined red numbers assigned to each white number. The red numbers will be randomized for each entry. To select a number, the user identifies the white number belonging to the PIN and pronounce the assigned red number.

Zhang et al. [46] proposed to enter a PIN with a gesture control armband to enable the PIN input with finger movements. The authors did not specify a particular HMD device. As entering of the PIN is done by an external device, the only requirement to the HMD is to show the PIN pad on the private display.
Enrollment: The user needs to put on the gesture control armband Myo and perform various finger taps, i.e., 20 taps for each finger except the thumb in order to build a personalized model of the finger taps. Then, the user sets up a PIN consisting of numbers from 0 to 7 using a separate device or the HMD device. To complete the enrollment, the user looks at the virtual PIN pad of the HMD and enters the selected PIN with finger taps.
Authentication: The user wears the Myo armband and looks at the randomized virtual PIN pad with numbers ranging from 0 to 7. The numbers are selected using finger taps. However, due to the bad accuracy of the Myo armband, the authors suggest to enter additionally the parity bits of the PIN or enter the PIN repeatedly, and accept the user once a specific percentage of right PIN numbers is reached.

Seo et al. [39] described a PIN based scheme by displaying random numbers and correcting them to the PIN with the use of touch gestures or voice. The scheme is proposed for the Google Glass and makes use of touch pad or voice recognition respectively.
Enrollment: The user chooses a 4-digit PIN using an external device or the same approach as for authentication; or a 4-digit PIN is assigned by the server and displayed to the user on the glass.
Authentication: Randomized numbers r_i ($i = 4$) are shown in a row. The user changes the number to their PIN p_i by either speaking out the correct PIN c_i which is defined as $(c_i + r_i) \bmod 10 = p_i$ or the user changes each r_i by scrolling to the correct PIN p_i with the touch pad. Once all 4 digits are correctly identified, the user confirms the input for verification.

Gheorghe et al. [15] proposed a PIN based scheme which displays a randomized PIN pad on the HMD and collect the PIN entry with gestures of the user captured by thermal residue. A particular HMD was not specified but would require a thermal camera on the front.
Enrollment: The user chooses a 4-digit PIN using a separate device or same approach as for authentication; or a 4-digit PIN is assigned by the server and displayed to the user on the glass.
Authentication: The user is shown a randomized touch pad and enters the PIN by tipping on the physical surface that faces the virtual PIN pad. The front camera captures the residual heat on the surface caused by the finger tip to define the position of the touch. The relative distance of the touches will determine the entered PIN.

Yadav et al. [44] implemented two PIN based schemes: 1) speaking out the indirect input randomly assigned to the actual PIN and 2) using touch gestures to select the numbers on a PIN pad starting at a random position. The schemes are proposed for the Google Glass and make use of voice recognition and touch pad respectively.
Enrollment: A 4-digit PIN is assigned by the server and displayed to the user on the glass or on a separate device. The assigned PIN does not have repeated, consecutive or neighboring digits.
Authentication: For the voice based PIN, the user is shown a PIN pad which consists of plain text digits and randomly mapped digits positioned next to the plain text digits in red color. When entering the PIN, the user speaks out the corresponding random digit. The glasses capture the input and reverse map the random digit into the real PIN and grants access when it matches with the stored PIN. For the touch-based PIN, the user is shown a randomized PIN pad. The PIN will be entered by navigating on the pad with forward and backward swipes and selecting a number by a tap on the touch pad. For each entry, the PIN pad will be re-randomized. The system grants access to the user when the entered PIN matches with the stored one.

Khare et al. [25] proposed to enter a PIN via single hand gestures by showing the number of fingers which correspond to the digit which needs to be entered. The authors did not implement the scheme on an HMD. The HMD would require a front camera.
Enrollment: The user chooses a PIN which consists of a combination of digits from 0-5. The PIN is entered several times with hand gestures to store them on the device.
Authentication: The user performs the hand gestures based on the combination of digits defined in the enrollment. If the performed gestures match with the stored ones, the system grants access to the user.

Bailey et al. [4] discussed to adapt the method of indirect password entry to the Google Glass. The approach can be used for PIN as well as textual passwords. The scheme takes use of the speech recognition system of the glass.
Enrollment: The password is assigned by the server and displayed to the user on the glass or on a separate device.
Authentication: The numbers on the PIN pad or the characters on the keyboard are assigned random characters and the user speaks out the random character associated to the elements of the password instead of pronouncing the password.

Bailey et al. [4] also discussed to use calculations to enter a PIN indirectly. The scheme is recommended to be deployed on the Google Glass and requires a speech recognition system.
Enrollment: The password is assigned by the server and displayed to the user on the glass or on a separate device.
Authentication: Random numbers in the length of the PIN are shown to the user on the private display. The user calculates the sum of PIN and the random number and speaks out the result mod 10 for each digit.

Li et al. [32] proposed ShadowKey which supplements the keypad with a shadow pad that consists of symbols of the keypad in a random order. The shadow pad will be randomized again after each input. The scheme is suggested for both PIN and textual password. The user speaks out the symbol on the shadow pad and the system stores the associated symbol on the keypad. An HMD was not specified but would need to be equipped with a voice recognition system.
Enrollment: The user chooses a password using a separate device or the same approach as for authentication; or a password is assigned by the server and displayed to the user on the AR HMD.

Authentication: The user speaks out "start" to activate the authentication process. The keypad will be displayed with the randomized shadow pad next to it. If the keypad is too large to fit into the display unit, the keypad will be separated in several smaller keypads and switched by saying "next". The user speaks out the symbols associated with the password one after the other. Once the whole password is entered, the user says "finish" to send the input to the server. The stored password and the input are compared to each other to verify the user.

4.2 Based on graphical passwords

This section presents the schemes which use recognition-based or recall-based graphical secrets for authentication.

Friström et al. [12] developed a pattern based scheme which is entered by free-form gaze gestures of the user. An HMD was not specified but would require an eye facing camera to track the gaze movement.
Enrollment: The user chooses a free-form pattern and enters the pattern at least three times with eye movement. The gaze data will be separated into horizontal and vertical eye movements and processed for feature extraction. The extracted features are stored in the database to be used as reference for authentication.
Authentication: The user enters the pattern password by moving the pupil accordingly. The gaze data will be processed and compared to the reference sample. If the captured data matches to a certain threshold with the reference data, the user will be accepted.

Funk et al.'s [13] scheme is based on graphical passwords composed of 3-D virtual objects. The objects are selected with head-gaze of the user captured by the HMD. The scheme was implemented for Microsoft HoloLens.
Enrollment: User selects a 4-objects-long password by moving the cursor of the HMD on a 3-D model which is randomly scattered in the field of view of the user and enters the password with an AirTap[1] gesture.
Authentication: The cursor of the HMD will be positioned on the virtual object with the use of head-gaze. To prevent involuntary selection of targets the dwell-to-select approach will be applied where the user needs to fixate the object for 1.5 seconds. If the input is false the entering process will be cancelled and the user needs to start from the beginning. If the input is correct, the user has three seconds to enter the next object. Otherwise the process will be cancelled, too.

Hadjidemetriou et al. [19] designed HoloPass - a scheme for graphical passwords consisting of patterns marked on a background picture. The scheme is proposed for the Microsoft HoloLens and is using gesture tracking or the HoloLens clicker for entering the password.
Enrollment: The user sees an image on the HMD and draw three gestures on the image which can be dots, lines or circles. Dots are entered with a tap, lines with a tap-and-hold at the staring point and moving the hand till the end point, and circles with a double tap-and-hold. After setting the three gestures, the user confirms the input.
Authentication: The user is shown the same image as during enrollment. The elements on the image act as a cue for positioning the gestures. The user places the three secret gestures on the image and confirms the input. The system grants access to the user if the gestures and the positioning are aligned with the stored password.

Bailey et al. [4] discussed to adapt the method of indirect password entry for a scheme which uses a grid of pictures to authenticate the user. The scheme is proposed for the Google Glass and make use of speech recognition, touch pad, or gyroscope & accelerometer.
Enrollment: The password consists of a set of pictures which is assigned by the server and displayed to the user on the glass or on a separate device.
Authentication: Grids of pictures which are assigned with random labels are shown to the user. The user selects those pictures which are part of the password by speaking out the assigned label or navigating and selecting by using head movement and the touch pad.

4.3 Based on haptic patterns

This section summarizes the schemes which use a tapping pattern entered on a touch surface to authenticate the user.

Islam et al. [21] designed a scheme which uses tapping gestures to authenticate the user. The tapping gestures are captured by a self-constructed touch pad which consists of two touch areas and is capable to differentiate different tapping types. The system was tested on the Epson Moverio BT-200 glass.
Enrollment: Users open the password creation system on the PC to choose or get a tapping password consisting of four items. Ten gestures including different flat and finger tap gestures are available for the password.
Authentication: User enters the gesture password on the touch pad mounted on the temple of the glasses. After input of each password item, the glasses give feedback on the private display by showing a highlighted rectangle (standard version) or the entered gesture symbol directly (disclosed version).

Yadav et al. [44] implemented a scheme for tapping patterns which are entered on the touch pad located on the temple of the glasses. The scheme was used for the Google Glass.
Enrollment: The user is assigned four touch gestures out of ten possible options which consists of various forms of swipes and taps. The gestures are displayed to the user on the glass or on a separate device.
Authentication: The pattern lock will be entered with the finger on the touch pad of the glasses. The system grants access to the user when the entered pattern matches with the stored one.

Hutchins et al. [20] developed the scheme beat-PIN that consists of beats entered via taps on a touch pad. Authors did not implement the scheme for a specific HMD.
Enrollment: The user creates a beat-PIN which can be from, e.g., a favorite song or jingle. The length of the beat-PIN was not specified by the authors. The user enters the beat-PIN several times for training the algorithm.
Authentication: The user enters the previously defined beat-PIN by tapping with the finger on the touch pad. The user will be authorized if the tapping pattern matches with the training sample.

[1] https://docs.microsoft.com/en-us/dynamics365/mixed-reality/guides/hl1

4.4 Based on semantic-knowledge passwords

Duezguen et al. [9] propose using the Zero-Trust Authentication (ZeTA) scheme by [18] on the Google Glass. The user answers a set of challenges based on the semantic knowledge of the secret. The answers are entered by speech, touch pad or head movement by using accelerometer and gyroscope sensors.
Enrollment: A secret will be generated by the system and assigned to the user. The enrollment needs to be performed on a private channel either with the HMD or with a separate device. The assigned secret consists of two or more words or pictures connected with logical connections AND or OR.
Authentication: The user answers a series of challenges, e.g., 14 challenges for PIN level security, with yes or no by using the available input methods. Thereby, the user determines if the presented attribute is related to the secret. Afterwards, the server checks the correctness of the answers and grants access to the user.

4.5 Based on two-factor authentication (2FA)

The following schemes take use of a second factor to verify the identity of the user. Thereby, either biometric data or something the user owns is captured in addition to the knowledge of the user.

A scheme based on two-factor authentication by using both user's knowledge and biometric data is proposed by *Yi et al.* [45]. The knowledge of the user is captured by answers to security questions which are only known to the user. The biometrics of the user are captured by head gestures provided for delivering the answers. The scheme was implemented for the Google Glass and is using the accelerometer and gyroscope sensors of the glass.
Enrollment: The user establishes a large set of "yes" / "no" security questions and provide the answers. Then, the user answers these security questions with head gestures while sitting still. The gestures are recorded with the glass. Based on these recordings gesture templates will be created after a process of normalizing, filtering errors and clustering. These gesture templates are used for recognizing the user during authentication.
Authentication: A set of security questions are displayed on the screen of the glass. The user is answering them with head gestures (e.g. nodding or shaking). Features extracted from the gestures are validated by a classifier which compares the current gestures with the gesture templates assigned to the user profile. The system grants access if the answers are correct and the gestures belong to the claimed user.

Another scheme by *Findling et al.* [11] uses gaze gestures to enter a pattern either with closed or open eyes. The user authenticates by the secret of a specific gaze gesture combination and also by providing the individual gaze behaviour. The gestures are entered by pupil movement. An HMD was not specified but it must include EOG sensors inside the HMD which are positioned on the nose pads and the bridge of the glasses' frame.
Enrollment: The user first records multiple samples of the nine available gaze gestures. These samples are used to train the gaze gesture recognition model of the user to be able to distinguish the entered gaze gestures. Then, the user sets the gaze gesture password with a length of 7 to 9 gestures. The password is extracted and recognized by the gaze gesture model and stored for comparison during authentication.
Authentication: The user performs the gesture passwords. Then, the features of the gaze input are extracted to recognize the gaze gesture types based on the gaze gesture model. The extracted gesture types are compared with the stored password and a decision is made on accepting or rejecting the user.

Lu et al. [34] proposed to use a freestyle in-air handwriting passcode to authenticate with the knowledge of the writing content and with behavioural biometrics by capturing the writing style. The secret passcode consists of a string which is written in the air via hand movement. The scheme was not implemented on an HMD and would require a hand motion tracking unit to perform the authentication.
Enrollment: The user creates an account by choosing a passcode and writing the passcode in the air five times. The signals of these writings are generated and stored as the registration signal set to compare it with the signals during authentication.
Authentication: The user writes the passcode in the air and terminates the sign by keeping the hand still for one second. Then, the signal is generated and a matching score based on the registration signal set is calculated. The user is going to be accepted, if the score is below a specific threshold.

A scheme by *Azimpourkivi et al.* [1] uses user's knowledge and possession by letting the user taking a photo of an arbitrary object the user has chosen as the secret. The object the user is owning is called trinket. The secret knowledge consists of the trinket itself as well as the angle and section of the trinket from which the photo is captured. The HMD would require a front camera, but the authors do not mention any specific HMD the scheme can be used for.
Enrollment: The user chooses a trinket and take several photos of a specific section of the trinket from a specific angle. After checking the quality and consistency, the pictures are stored as reference pictures.
Authentication: The user takes a photo from the chosen trinket which needs to be from the same section and angle as the reference pictures. If the photo matches with the reference pictures, the HMD grants access to the user.

Funk et al.'s [13] scheme uses 3D coordinates in the real environment as the secret. Thereby, the user needs to know the spatial target and also be at this place to be able to enter the secret. The targets are selected with head-gaze of the user which is captured by the HMD. The scheme was implemented for Microsoft HoloLens.
Enrollment: User sets a 4-targets long password which can also be combined with 3-D virtual objects. The spatial password is entered by moving the cursor of the HMD on a position in the real world and enter with, e.g., an AirTap gesture. This position will then be marked with a 3D cube. For a hybrid password, users select a combination of virtual as well as spatial objects.
Authentication: The cursor of the HMD will be positioned on the spatial target with use of the head-gaze. To prevent involuntary selection of targets the dwell-to-select approach will be applied where the user needs to fixate the target for 1.5 seconds. If the input is false the entering process will be cancelled and the user needs to start from the beginning. If the input is correct, the user has three seconds to enter the next target. Otherwise the process will be cancelled, too.

5 USABILITY AND SECURITY OF THE SCHEMES

This section describes the evaluation of the 31 schemes regarding the assessment of their usability and security. 22 (71%) of the schemes were evaluated with a user study. In the user studies, 19 (61%) of the schemes were investigated with respect to their usability and 9 (29%) of the schemes with respect to their security. Only 6 (19%) of the schemes were analyzed regarding both usability and security in a user study.

5.1 Usability Considerations

The papers conducted various measurements to investigate the scheme's usability, i.e. enrollment and authentication time, success rate, input accuracy, satisfaction, memorability & learning effect, and perceived usability. The results of the most frequently measured usability dimensions are summarized in the appendix in Table 2 . 16 (84%) of the schemes whose usability was investigated include the evaluation of the scheme's efficiency by measuring the authentication time. The authentication time describes the duration for entering the password and confirming the input unless it is otherwise stated in the appendix in Table 2. 17 (89%) of the schemes whose usability was investigated considered the scheme's effectiveness. The effectiveness of the schemes were measured by the success rate of the user for authenticating to the system. It is important when considering the numbers in the table to keep in mind that the password space differs in the studies. Perceived usability was validated in 11 (58%) of the schemes whose usability was investigated by using self-made questionnaires or scales like the NASA TLX. The self-made questionnaires included the dimensions convenience/ease of use, speed, stability, confidence in reproducing the password, preference compared to other schemes, willingness to use now or willingness to use in future.

5.2 Security Considerations

We also reviewed the security of the proposed schemes by investigating the resistance of the schemes against shoulder-surfing attacks. 10 (67%) of the investigated schemes conducted an empirical study to evaluate the scheme's shoulder-surfing vulnerability and 5 (33%) delivered a mathematical proof to show that the scheme is resistant.

We classify the schemes' resistance according the four types of shoulder-surfing attacks described by Wiese & Roth [43]. The authors differentiate between observing an authentication session directly by the adversary and recording the session and watching the recording. They also consider the number of observations or recordings of the adversary. A high number of recordings or observations are classified as multiple recordings or insider observer respectively. A small number of session recordings or observations are classified as single recordings or opportunistic observer respectively.

Besides of GesturePIN [25], all of the proposed schemes for alphanumeric passwords are based on randomized keypads. Thus, they are resistant against recordings as well as observations regardless of the number of authentication sessions being attacked, if there are no repetitions within the PIN. Note, we assume that the virtual elements displayed to the user are not visible to the outsider. This is, however, not always the case. Displays of HMD like Google Glass are not completely private as the output image is visible to the outside on the front of the prism in a reduced size.

The shoulder-surfing resistance of proposed schemes for graphical passwords differ depending on their input methods as well as randomization of the graphical password. Schemes without randomized graphical passwords like LookUnlock (spatial) [13] or HoloPass [19] are less resistant against observations or recordings while LookUnlock (virtual) [13] and Covered Graphical Password [4] show that randomized graphical passwords are resistant against insider observer. Free-form Gaze Pwd [12] which uses eye movement to enter a graphical pattern was shown to be not resistant against single recording if the user's eyes are not covered completely by the HMD.

Schemes for haptic patterns, like GlassPass [21] or Google built-in [44] seem to be not resistant against observations or even recordings as the input of the pattern can be easily captured by the outsider. But, a more sophisticated pattern like Beat-PIN [20] shows some resistance against observations with increased pattern length.

The ZeTA scheme [9] uses semantic connections of concepts to enter the secret in a challenge-response fashion via innate human-based computation. This makes the scheme resistant against both observations and recordings as the responses to the challenges do not disclose any information regarding the secret.

The schemes based on Two-Factor Authentication show a higher resistance if their second factor is less vulnerable to shoulder-surfing attacks. GlassGesture [45] uses additionally user's biometrics which are hard to mimic as the results confirm a 0% success rate for a single recording attack. The same holds true for closed-eye GazeGesturePwd, though the open-eye version seems to be very vulnerable against single recording. Also Passcodes [34] seem to be easy to mimic when the authentication session is recorded. Pixie [1] uses a trinket as a token, but the authors show that knowing the trinket type provides no significant advantage to the attacker. Thus, figuring out the trinket type by observing the authentication does not make the user vulnerable. But, the success chances of an attacker using recordings of the authentication session need to be investigated. Table 2 in the appendix summarizes the shoulder-surfing resistance of each scheme and the underlying evaluation methods.

6 DISCUSSION

This section discusses the results and identify research gaps for future work.

Lack of schemes compatible with textual passwords. Textual passwords established themselves as one of the most known and widely used types of passwords [6, 22]. Yet, only little attention has been paid regarding their implementation in AR HMDs: Merely three of the proposals in the literature – namely Passcode [34], Covered Char [4] and ShadowKey Char [32] – are compatible with textual passwords and could therefore be directly used with third-party services. Covered Char and ShadowKey Char, which are using indirect input with randomized characters, are resistant to shoulder-surfing, but suffer from usability as virtual keyboards of HMDs are very cumbersome to use [25]. Thus, current research is missing textual password

schemes which are sufficiently secure and usable. Applications on the HMD provided by third parties, e.g, payments, meetings or remote control systems, usually require textual passwords to use their services. To avoid security and usability issues while using AR HMD, proper solutions need to be designed to meet these requirements. For example, using a password manager to authenticate to applications on the HMD can be investigated in future research. Due to the prevalence of text passwords, this seems like an oversight, if users are to adopt AR HMDs on a wider scale.

Schemes have low security levels. About 61% of the schemes in the literature were designed with only PIN-level security in mind. While many schemes could be scaled to have much larger password spaces, the implications regarding their security and usability properties remain unclear. Thus one of the most important revelations from our literature review is that AR HMDs seem to have inspired mostly authentication research with lower security levels in mind. So it seems the issue lies not only with adequate proposals for textual passwords, but rather generally with authentication schemes that were designed with higher security levels in mind.

High number of PIN based scheme proposals. PINs are one of the oldest password types and are used regularly for various devices and services. The PIN schemes for AR HMD show high scores regarding their effectiveness. The high familiarity of people with PINs might explain the better performance of PINs compared to more novel schemes with graphical passwords or haptic patterns. Especially, gTapper [31], which proposes to enter the PIN via swipes on the touch pad, was rated with a very high perceived usability. The familiarity with touch pads from other devices like laptops might also have influenced users perception. But, further studies are needed to investigate the influence of scheme familiarity on usability. When the PIN is entered via speech like in gTalker [31], the authentication took much longer and was also perceived less user-friendly. Speech recognition systems on the HMD can be very slow and error prone [16]. Thus, schemes have to make sure to have reliable and robust speech recognition systems before using it for authentication.

Methods to avoid shoulder-surfing. The schemes use different means to combat the threat of shoulder-surfing attacks. Very often they make use of the private communication channel in combination with randomization. The private display shows the keyboard or graphical elements in a randomized order that an attacker cannot detect the password by observing the password entry, like in gTapper [31] or LookUnlock (virtual) [13]. Also covert input channels can protect from shoulder-surfing. E.g., entering the password with eye gaze provides resistance if the eyes are covered by the HMD, like in GazeGesturePwd [11] or Free-form GazePwd [12]. As haptic patterns are entered via an unprotected channel, these schemes were more vulnerable to shoulder-surfing. Another effective measure is using indirect input, like in MaskedPwd (voice) [39] or ShadowKey PIN/Char [32], which assign randomized other elements to the keyboard elements. 2FA can be effective as well, e.g., GlassGesture [45] or Pixie [1], if the second factor is not able to be mimicked by the attacker. For future studies, further techniques known to be effective against shoulder-surfing can be investigated: (1) Obfuscating the input by adding distractors into the password entry like for example in [26] - this can be useful when the display is not private or the input reveals the password; (2) portfolio authentication by only entering parts of the password like in [7] and [8].

Lack of uniform evaluations of different scheme types. Another important problem that became apparent from the literature review is that the evaluation methodologies of the different schemes vary greatly and create a very fragmented picture of the design space, making it difficult to assess and compare the schemes to each other. Authentication schemes' primary purpose is to secure systems. Yet the majority of schemes were not even investigated regarding their security: 22 (71%) of the schemes were not measured by the schemes security. Usability evaluations were somewhat more common, but still 12 (39%) of the proposals are missing usability evaluations. Overall, only 6 (19%) of the schemes were analyzed in both usability and security and thus can provide more detailed insights on the applicability of the schemes. Additionally, 18 (58%) are not fully implemented on an HMD which makes a realistic assessment of the scheme very difficult. Thus, for future work, more comparative studies which implement the schemes with a uniform password space and evaluate them with the same usability and security criteria are needed.

7 CONCLUSION

This study provides a comparative analysis of knowledge-based authentication schemes designed to be applicable for AR HMDs. The literature search yielded 18 relevant papers, which described a total of 31 scheme proposals. These schemes cover the following secret types: alphanumeric passwords, graphical passwords, haptic patterns, semantic-knowledge passwords, and schemes with two-factor authentication. About 70% of the schemes were evaluated with a user study regarding their usability or security, but only about 20% were analyzed regarding both usability and security. The most commonly measured usability aspects were efficiency, effectiveness and perceived usability. About half of the schemes were evaluated regarding their resistance against shoulder-surfing attacks. As the presented schemes vary in their maturity level, strength of their security and evaluation measurements, a uniform implementation and evaluation of promising schemes can be considered for future work.

ACKNOWLEDGMENTS

This work was supported by funding of the Helmholtz Association (HGF) through the Competence Center for Applied Security Technology (KASTEL) in the POF subtopic 46.23.01 called "Methods for Engineering Secure Systems" and a gift from Facebook. We would also like to acknowledge the Inclusive Security and Privacy-focused Innovative Research in Information Technology (InSPIRIT) Lab at the University of Denver for supporting this work.

REFERENCES

[1] Mozhgan Azimpourkivi, Umut Topkara, and Bogdan Carbunar. 2017. Camera based two factor authentication through mobile and wearable devices. *Interactive, Mobile, Wearable and Ubiquitous Technologies* 1, 3 (2017), 1–37.
[2] Ronald T Azuma. 1997. A survey of augmented reality. *Presence: teleoperators & virtual environments* 6, 4 (1997), 355–385.
[3] Ahmed Fraz Baig and Sigurd Eskeland. 2021. Security, Privacy, and Usability in Continuous Authentication: A Survey. *Sensors* 21, 17 (2021), 5967.

[4] Daniel V Bailey, Markus Dürmuth, and Christof Paar. 2014. "Typing" passwords with voice recognition: How to authenticate to Google Glass. In *Proc. of the Symposium on Usable Privacy and Security*. Citeseer, Citeseer, CA, USA, 1–2.

[5] Mohammadreza Hazhirpasand Barkadehi, Mehrbaksh Nilashi, Othman Ibrahim, Ali Zakeri Fardi, and Sarminah Samad. 2018. Authentication systems: A literature review and classification. *Telematics and Informatics* 35, 5 (2018), 1491–1511.

[6] Joseph Bonneau, Cormac Herley, Paul C Van Oorschot, and Frank Stajano. 2012. The quest to replace passwords: A framework for comparative evaluation of web authentication schemes. In *SOUPS*. IEEE, CA, USA, 553–567.

[7] Antonella De Angeli, Mike Coutts, Lynne Coventry, Graham I Johnson, David Cameron, and Martin H Fischer. 2002. VIP: a visual approach to user authentication. In *Proceedings of the AVI*. Elsevier, London, UK, 316–323.

[8] Antonella De Angeli, Lynne Coventry, Graham Johnson, and Karen Renaud. 2005. Is a picture really worth a thousand words? Exploring the feasibility of graphical authentication systems. *IJHCS* 63, 1-2 (2005), 128–152.

[9] Reyhan Duezguen, Peter Mayer, Sanchari Das, and Melanie Volkamer. 2020. Towards secure and usable authentication for augmented and virtual reality head-mounted displays. In *WAY Workshop*. WAY, Virtual, 1–6.

[10] Pedro Ferreira, João Orvalho, and Fernando Boavida. 2007. Security and privacy in a middleware for large scale mobile and pervasive augmented reality. In *2007 15th SOFTCOM*. IEEE, Croatia, 1–5.

[11] Rainhard Dieter Findling, Tahmid Quddus, and Stephan Sigg. 2019. Hide my gaze with EOG! towards closed-eye gaze gesture passwords that resist observation-attacks with electrooculography in smart glasses. In *MoMM*. ACM, USA, 107–116.

[12] Eira Friström, Elias Lius, Niki Ulmanen, Paavo Hietala, Pauliina Kärkkäinen, Tommi Mäkinen, Stephan Sigg, and Rainhard Dieter Findling. 2019. Free-Form Gaze Passwords from Cameras Embedded in Smart Glasses. In *MoMM*. ACM, USA, 136–144.

[13] Markus Funk, Karola Marky, Iori Mizutani, Mareike Kritzler, Simon Mayer, and Florian Michahelles. 2019. Lookunlock: Using spatial-targets for user-authentication on hmds. In *Extended Abstracts CHI*. ACM, NY, USA, 1–6.

[14] Ethan Gaebel, Ning Zhang, Wenjing Lou, and Y Thomas Hou. 2016. Looks good to me: Authentication for augmented reality. In *TrustED*. ACM, NY, USA, 57–67.

[15] Gabriela Gheorghe, Nicolas Louveton, Benoît Martin, Benjamin Viraize, Louis Mougin, Sébastien Faye, and Thomas Engel. 2016. Heat is in the eye of the beholder: Towards better authenticating on smartglasses. In *2016 9th International Conference on Human System Interactions (HSI)*. IEEE, Portsmouth, UK, 490–496.

[16] Jens Grubert, Lukas Witzani, Eyal Ofek, Michel Pahud, Matthias Kranz, and Per Ola Kristensson. 2018. Text entry in immersive head-mounted display-based virtual reality using standard keyboards. In *VR*. IEEE, Germany, 159–166.

[17] Jan Gugenheimer, Christian Mai, Mark McGill, Julie Williamson, Frank Steinicke, and Ken Perlin. 2019. Challenges using head-mounted displays in shared and social spaces. In *Extended Abstracts of CHI*. ACM, NY, USA, 1–8.

[18] Andreas Gutmann, Karen Renaud, Joseph Maguire, Peter Mayer, Melanie Volkamer, Kanta Matsuura, and Jörn Müller-Quade. 2016. Zeta-zero-trust authentication: Relying on innate human ability, not technology. In *EuroS&P*. IEEE, Germany, 357–371.

[19] George Hadjidemetriou, Marios Belk, Christos Fidas, and Andreas Pitsillides. 2019. Picture passwords in mixed reality: Implementation and evaluation. In *Extended Abstracts of the 2019 CHI*. ACM, NY, USA, 1–6.

[20] Ben Hutchins, Anudeep Reddy, Wenqiang Jin, Michael Zhou, Ming Li, and Lei Yang. 2018. Beat-pin: A user authentication mechanism for wearable devices through secret beats. In *ASIACCS*. ACM, NY, USA, 101–115.

[21] MD Rasel Islam, Doyoung Lee, Liza Suraiya Jahan, and Ian Oakley. 2018. Glass-pass: Tapping gestures to unlock smart glasses. In *AH'18*. ACM, NY, USA, 1–8.

[22] Priti Jadhao and Lalit Dole. 2013. Survey on authentication password techniques. *IJSCE* 3, 2 (2013), 67–68.

[23] John M Jones, Reyhan Duezguen, Peter Mayer, Melanie Volkamer, and Sanchari Das. 2021. A literature review on virtual reality authentication. In *HAISA*. Springer, Cham, 189–198.

[24] Hassan Khan, Urs Hengartner, and Daniel Vogel. 2018. Augmented reality-based mimicry attacks on behaviour-based smartphone authentication. In *MobiSys*. ACM, NY, USA, 41–53.

[25] Akhil Khare, Vinaya Kulkarni, and Akhilesh Upadhayay. 2012. A Collaborative Augmented Reality System Based On Real Time Hand Gesture Recognition. In *Global Journal of Computer Science and Technology*. Global Journals, US, 47–51.

[26] Sung-Hwan Kim, Jong-Woo Kim, Seon-Yeong Kim, and Hwan-Gue Cho. 2011. A new shoulder-surfing resistant password for mobile environments. In *IMCOM*. ACM, NY, USA, 1–8.

[27] Barbara Kitchenham. 2004. Procedures for performing systematic reviews. *Keele, UK, Keele University* 33, 2004 (2004), 1–26.

[28] Gregory Kramida. 2015. Resolving the vergence-accommodation conflict in head-mounted displays. *TVCG* 22, 7 (2015), 1912–1931.

[29] Christopher Kreider. 2018. The Discoverability of Password Entry Using Virtual Keyboards in an Augmented Reality Wearable: An Initial Proof of Concept. In *Southern Association for Information Systems*. AISeL, UK, 1–6.

[30] Lingjun Li, Xinxin Zhao, and Guoliang Xue. 2013. Unobservable re-authentication for smartphones.. In *NDSS*, Vol. 56. NDSS, USA, 57–59.

[31] Yan Li, Yao Cheng, Weizhi Meng, Yingjiu Li, and Robert H Deng. 2021. Designing leakage-resilient password entry on head-mounted smart wearable glass devices. *IEEE Transactions on Information Forensics and Security* 16 (2021), 307–321.

[32] Yingjiu Li, Qiang Yan, and Robert H Deng. 2015. ShadowKey: A Practical Leakage Resilient Password System. In *Leakage Resilient Password Systems*. Springer, Cham, 53–64.

[33] Jonathan Liebers and Stefan Schneegass. 2020. Gaze-based Authentication in Virtual Reality. In *ETRA*. ACM, USA, 1–2.

[34] Duo Lu, Yuli Deng, and Dijiang Huang. 2021. Global Feature Analysis and Comparative Evaluation of Freestyle In-Air-Handwriting Passcode for User Authentication. In *ACSAC*. ACM, NY, USA, 468–481.

[35] Peter Mayer and Melanie Volkamer. 2018. Addressing misconceptions about password security effectively. In *STAST*. ACM, NY, USA, 16–27.

[36] Naheem Noah and Sanchari Das. 2021. Exploring evolution of augmented and virtual reality education space in 2020 through systematic literature review. *Computer Animation and Virtual Worlds* 32, 3-4 (2021), e2020.

[37] Marc Parveau and Mehdi Adda. 2018. 3iVClass: a new classification method for virtual, augmented and mixed realities. *Procedia Computer Science* 141 (2018), 263–270.

[38] Farah Fayaz Quraishi, Summera Ashraf, and Manzoor Ahmad Chachoo. 2016. Fingerprint Feature Extraction, Identification and Authentication: A Review. *IJRRMCSIT* 2 (2016), 156–160. Issue 2.

[39] Hwajeong Seo, Jiye Kim, Howon Kim, and Zhe Liu. 2017. Personal identification number entry for Google glass. *C&EE* 63 (2017), 160–167.

[40] Sophie Stephenson, Bijeeta Pal, Stephen Fan, Earlence Fernandes, Yuhang Zhao, and Rahul Chatterjee. 2022. SoK: Authentication in Augmented and Virtual Reality. In *S&P*. IEEE Computer Society, USA, 1552–1552.

[41] Ivan E Sutherland. 1968. A head-mounted three dimensional display. In *Proceedings of fall joint computer conference*. ACM, NY, USA, 757–764.

[42] Jane Webster and Richard T Watson. 2002. Analyzing the past to prepare for the future: Writing a literature review. *MIS quarterly* 26, 2 (2002), xiii–xxiii.

[43] Oliver Wiese and Volker Roth. 2016. See you next time: A model for modern shoulder surfers. In *MobileHCI*. ACM, Florence, Italy, 453–464.

[44] Dhruv Kumar Yadav, Beatrice Ionascu, Sai Vamsi Krishna Ongole, Aditi Roy, and Nasir Memon. 2015. Design and analysis of shoulder surfing resistant pin based authentication mechanisms on google glass. In *FC*. Springer, Germany, 281–297.

[45] Shanhe Yi, Zhengrui Qin, Ed Novak, Yafeng Yin, and Qun Li. 2016. Glassgesture: Exploring head gesture interface of smart glasses. In *INFOCOM*. IEEE, USA, 1–9.

[46] Ruide Zhang, Ning Zhang, Changlai Du, Wenjing Lou, Y Thomas Hou, and Yuichi Kawamoto. 2017. AugAuth: Shoulder-surfing resistant authentication for augmented reality. In *ICC*. IEEE, Paris, France, 1–6.

A APPENDIX

Table 2: Security and usability evaluations of the schemes, x=undefined, e=empirical, t=theoretical, SSR=shoulder-surfing resistance, keyboard=all elements of a standard keyboard, *only with private display.

				Usability			Security	
Password Type	Paper	Scheme Name	Password Space (Password Length | Alphabet)	Authentication Time	Success Rate	Perc. Usability	SSR	Evaluation of SSR
Alphanumeric Password	Li et al. (2021)	gTapper	6|10	11.2s	98.3%	Willingness to use: 100%	Observation, Recording (also repeatedly)	theoretical proof*
		gRotator	6|10	15.6s	98.2%	Willingness to use 56.1%	Observation, Recording (also repeatedly)	theoretical proof*
		gTalker	6|10	21.8s	98.2%	Willingness to use: 58.5%	Observation, Recording (also repeatedly)	theoretical proof*
	Zhang et al. (2017)	AugAuth	x | 8	-	finger recognition accuracy: 86%	-	Observation, Recording (also repeatedly)	theoretical*
	Seo et al. (2017)	MaskedPwd (voice)	4|10	(UI showed pwd on top) 4.8s	100 %	-	Recording (Observation, also repeatedly)	theoretical*
		MaskedPwd (touch)	4|10	(UI showed pwd on top) 5.8s	100 %	-	Recording (Observation, also repeatedly)	theoretical*
	Gheorghe et al. (2016)	Thermal Touch Input	4|10	-	-	-	Recording, Observation (also repeatedly)	implicated*
	Yadav et al. (2015)	VBP	4|10	6.4s	83%	Convenience: 3.53, Speed: 4.20, Stability: 3.53	Observation, Recording (also repeatedly)	theoretical*
		TBP	4|10	13.9s	87%	Convenience: 2.57, Speed: 2.33, Stability: 3.90	Observation, Recording (also repeatedly)	theoretical*
	Bailey et al. (2014)	Indirect input - PIN	x | 10	-	-	-	Observation, Recording (also repeatedly)	theoretical*
		Covered PIN	x | 10	-	-	-	Observation, Recording (also repeatedly)	theoretical*
		Covered Char Pwd	x | keyboard	-	-	-	Observation, Recording (also repeatedly)	theoretical*
	Khare et al. (2011)	GesturePIN	x | 6	-	-	-	no resistance	-
	Li et al. (2015)	ShadowKey PIN	x | 10	-	-	-	Recording, Observation (also repeatedly)	theoretical proof*
		ShadowKey Char Pwd	x | keyboard	-	-	-	Recording, Observation (also repeatedly)	theoretical proof*

Continues on next page

Table 2 – Continued from previous page

				Usability			Security	
Password Type	Paper	Scheme Name	Password Space (Password Length | Alphabet)	Authentication Time	Success Rate	Perc. Usability	SSR	Evaluation of SSR
Graphical Password	Friström et al. (2019)	Free-from gaze pwd	x | x	4.64s	EER: 16%, FAR: 12%, FRR: 19%	confident in reproducing pwd: 3.24, comfortable: 2.18, practical compared to other pwds: 2.35	Recording (1x)[e]	success rate: 17.5% if user's eyes are visible
	Funk et al. (2019)	LookUnlock (virtual)	4 | x	-	-	-	Recording[t], Observation (also repeatedly)[e]	success rate: 0%
	Hadjidemetriou et al. (2019)	HoloPass	x | x	-	-	80% preferred Holopass, 20% preferred textual pwd for AR	no resistance	-
	Bailey et al. (2014)	Covered Graphical Password	x | x	-	-	-	Recording, Observation (also repeatedly)	theoretical*
Haptic Pattern	Islam et al. (2018)	GlassPass (chosen, disclosed)	4|10	2.0s	96%	NASA TLX (1=low, 20=high): 9-11	no resistance	-
		GlassPass (assigned, disclosed)	4|10	2.6s	93%	NASA TLX (1=low, 20=high): 9-11	no resistance	-
		GlassPass (chosen, non disclosed)	4|10	1.9s	96%	NASA TLX (1=low, 20=high): 9-11	no resistance	-
		GlassPass (assigned, non disclosed)	4|10	2.7s	96%	NASA TLX (1=low, 20=high): 9-11	no resistance	-
	Yadav et al. (2015)	Google Built-in	4|10	5.6s	68%	Convenience: 3.10, Speed: 2.90, Stability: 3.20	no resistance	theoretical
	Hutchins et al. (2018)	Beat-PIN	6-10 | 10^7	tested with smart watch: 1.7s	EER: 7.2%; sitting: FRR 4.5%, FAR 8.0%; fast walking: FRR 9.0%, FAR 8.3%	-	Recording, Observation (3x)[e]	success rates observation: 3.2% - 1.8%; recording: 39.3% - 11.3%
Semantic-Knowledge Password	Duezguen et al. (2020)	ZeTA	14 | 2	-	-	-	Observation, Recording (also repeatedly)	theoretical
2FA	Yi et al. (2016)	GlassGesture	x | 2	gesture recognition: 0.03s, classification: 0.03s	gesture recognition: 96%, TAR: 92.38%, FAR: 0.13%, TRR: 99%	-	Recording (1x)[e]	success rate: 0%
	Findling et al. (2019)	GazeGesturePwd (closed eye)	7-9 | 9	10.8s	gesture recognition: 80.0%-71.2%, TAR: 44.7%-36.8%	-	Recording (1x)[e]	success rate: 0%
		GazeGesturePwd (opened eye)	7-9 | 9	10.0s	gesture recognition: 86.5%-76.3%, TAR: 54.8%-28.6%	-	Recording (1x)[e]	success rate: 61%
	Lu et al. (2021)	Passcode	x | x	-	EER: 1.83-5.10%, FAR: 7,4%	90	Recording (1x)[e]	success rate: 29-60%
	Azimpourkivi (2017)	Pixie	1 | x	9.14s	83,11%	perceived ease of use: 95% agree / strongly agree, fast login: 68% agree / str. agree,	Observation (also repeatedly)[e]	no sig. advantage of knowing trinket type
	Funk et al. (2019)	LookUnlock (spatial)	4 | x	-	-	-	Observation (repeatedly)[e]	success rate: 5.9%
		LookUnlock (hybrid)	4 | x	-	-	-	Observation (repeatedly)[e]	success rate: 3.7%